06 — EU AI Act & Security Review (Mission 03)

Station: AI Security Officer
Mission: 03 | **Squadron:** Colby | **Officer:** Mubina Rahaman Jerin
Scope: `01–04` (attention core, RoPE, GQA/KV-cache, memory audit) | **Legal basis:** Regulation (EU) 2024/1689 (AI Act), as amended by the Digital Omnibus | **Review date:** 2026-10-23

---

1. Classification

Question	Answer
Is this code an "AI system" (Art. 3(1))?	**Not on its own.** These are building blocks (attention layers, a cache, benchmarks) with random weights; they make no inferences for a user.
Would AURA built on them be in scope?	**Yes.** A deployed assistant using these layers is an AI system. The Mission 01 and 02 findings (Art. 50 transparency, no prohibited or high-risk use) still apply.
Are we a GPAI model provider (Art. 53)?	**No.** We train nothing and release no model. If the squadron ever trained and released a general-purpose model, Art. 53 would apply: technical documentation (Annex XI, which includes known or estimated energy use), a training-data summary and a copyright policy.
Is research exempt?	Yes, research and development before placing on the market is outside the Act (Art. 2(6), 2(8)). We still check as if AURA were deployed.

2. Why this mission matters for the AI Act

The AI Act asks for **robustness and cybersecurity** in two places that touch this mission directly:

Article	Who	Requirement	Link to Mission 03
Art. 15	providers of high-risk AI systems	resilient against errors, faults and attempts by third parties to exploit vulnerabilities	the KV-cache DoS in `04` §2 is exactly such an exploit: one client can crash service for everyone
Art. 55(1)(d)	providers of GPAI models with systemic risk	adequate cybersecurity protection for the model and its physical infrastructure	serving infrastructure must survive resource-exhaustion attacks

AURA is not high-risk (see Mission 01, `06_AI_Act_Compliance.md`), so Art. 15 is not legally binding for us. We use it as the quality bar anyway, because a navigation assistant that crashes under load fails its users.

3. Checklist for this mission

#	Check	Status	Evidence
1	No personal data processed or stored	✓	all tensors are random; benchmarks store only numbers in `results/`
2	Results reproducible (fixed seeds, documented hardware assumptions)	✓	seeds in every script; H100 figures marked as vendor specs; CPU timings marked as "this machine"

#	Check	Status	Evidence
3	Resource-exhaustion risk identified	✓	`04` §2: naive server crashes at the 6th malicious session for 600 tokens
4	Mitigation specified	✓	`04` §3: PagedAttention + per-client quota + session cap survives the simulated attack
5	Energy and efficiency considered	✓	GQA cuts KV-cache memory traffic by 75%; FlashAttention removes the N^2 intermediate traffic. Less data moved means less energy per token
6	Limits stated honestly	✓	DoS results are a simulation with an assumed 4 GiB workspace; no real GPU was attacked

4. Actions before deployment

1. Deploy AURA only behind authentication with per-client token quotas and session caps (`04` §3.4).
2. Log KV-cache occupancy per client and alert on abnormal growth (supports the logging spirit of Art. 12).
3. Keep the Art. 50 disclosure from Mission 01: users must know they are talking to an AI.
4. If the squadron ever trains or fine-tunes and releases a model, prepare Annex XI documentation, including energy use.

Student assessment for a course assignment, not legal advice.